

Active Directory aur Network Hacking – Professional Lab Manual

Prepared By: Syed Ghous

2. Definition (Active Directory Kya Hai?)

Active Directory (AD) ek centralized database service hai jo Windows domain networks mein users, computers, aur unke security permissions ko control karti hai. Ye network ka "Brain" hota hai jahan se saare access rights decide hote hain.

3. Ye Kaam Kya Karta Hai?

AD ka main maqsad network resources ko organize karna hai. Ye ensure karta hai ke:

- Har user sirf unhi files ko access kar sake jo uske department ki hain.
- Admin poore network ke computers ko ek hi jagah se update ya monitor kar sake.
- Login credentials (username/password) ka record maintain rahe.

4. Ye Kaam Kaise Karta Hai?

AD **Domain Controller (DC)** ke zariye kaam karta hai. Jab bhi koi user login karta hai, to DC check karta hai ke kya ye user valid hai? Agar haan, to wo user ko network resources ka access deta hai. Hacking mein, agar koi hacker DC ka access le le, to wo poore network ka "God" ban jata hai.

5. Iski Kismy (Types)

1. **Domain Services (AD DS):** Sabse common, jo users aur computers manage karti hai.
2. **Federation Services (AD FS):** Dosri companies ya cloud ke saath access share karne ke liye.
3. **Certificate Services (AD CS):** Digital certificates aur encryption keys manage karne ke liye.
4. **Lightweight Directory Services (AD LDS):** Un apps ke liye jinhein poora AD nahi chahiye hota.

Step 1: Environment Setup (Lab)

- **Virtual Machine:** Apne PC par VMware ya VirtualBox install karein.
- **ISO File:** Windows Server 2022 aur Kali Linux ki ISO file download karein.

6. User Manual (Step-by-Step Guide)

Step 2: Enumeration (Network Scanning)

- Terminal mein **nmap** command chalayein: `nmap -sV -p- <Target-IP>`
- Isse aapko pata chalega ke kaunse ports khule hain.

Step 3: Exploitation

- **Metasploit Framework** ka istemal karein. Command: `msfconsole`.
- Specific vulnerability ke liye `use exploit/<path>` ka command use karein.

Step 4: Privilege Escalation

- System mein access milne ke baad, `whoami /priv` check karein.
- **WinPEAS** script run karein taake system ki hidden kamzoriyan nazar aa sakein.

Step 5: Persistence

- System mein wapas access pane ke liye ek "Backdoor" banayein (e.g., `netsh` ya `Registry key` modification).

Warning: Yeh manual sirf authorized lab environments aur practice ke liye hai. Ise bina permission kisi network par apply karna illegal hai.

Q&A

Q: Active Directory kya hai? A: Ye Windows network ka central database hai jo users, computers aur resources ko manage karta hai.

Q: Domain Controller (DC) ka kaam kya hai? A: Ye login requests ko authenticate karta hai aur policy apply karta hai.

Q: Kerberos kya hai? A: Ye AD mein default authentication protocol hai jo "tickets" use karta hai.

Q: Nmap kis liye use hota hai? A: Network scanning aur open ports dhundne ke liye.

Q: Privilege Escalation kya hai? A: Ek low-level user se admin rights hasil karna.

Q: Lateral Movement kya hai? A: Network mein ek machine se dusri machine tak access gain karna.

Q: Kerberoasting kya hai? A: Service account ke password hashes chori karne ka attack.

Q: Mimikatz kya karta hai? A: Memory se plaintext passwords aur hashes extract karta hai.

Q: Pass-the-Hash (PtH) attack kya hai? A: Password janne ke bajaye, sirf hash use karke login karna.

Q: LDAP ka default port kya hai? A: TCP port 389.

Q: GPO ka full form kya hai? A: Group Policy Object.

Q: Persistence ka maqsad kya hai? A: System restart hone ke baad bhi access barkarar rakhna.

Q: BloodHound tool kyun use hota hai? A: AD mein attack paths dhundne ke liye.

Q: Enumeration kya hai? A: Network se users, groups, aur machines ki list nikalna.

Q: AS-REP Roasting kya hai? A: Wo accounts jin par pre-authentication disabled ho, unke hashes nikalna.

Q: WinPEAS ka use? A: Windows mein local privilege escalation points dhundne ke liye.

Q: SMB protocol ka kya kaam hai? A: File sharing aur printing manage karna.

Q: Hash kya hota hai? A: Data ko encrypt karke banaya gaya unique alphanumeric string.

Q: Least Privilege policy kya hai? A: User ko sirf utna access dena jitna kaam ke liye zaroori ho.

Q: MFA kya hai? A: Multi-Factor Authentication (security badhane ke liye).

Q: Forest aur Tree mein kya farq hai? A: Tree ek ya zyada domains ka group hai, Forest ek ya zyada trees ka group hai.

Q: DNS ka role AD mein kya hai? A: Computers ko IP address aur naam se locate karna.

Q: Golden Ticket attack kya hai? A: TGT (Ticket Granting Ticket) ko fake karke poore domain ka control lena.

Q: Netsh command kya hai? A: Network configuration modify karne ka tool.

Q: Vulnerability kya hoti hai? A: System ki wo kamzori jise hacker exploit kar sakta hai.

Long Q&A

Active Directory (AD) ka Architecture aur Kerberos Authentication kaise kaam karta hai?

Answer: Active Directory ek hierarchical structure hai jo Forests, Trees, aur Domains par mushtamil hota hai. Sabse upar "Forest" hota hai, uske andar "Trees", aur Trees ke andar "Domains". Iska central component Domain Controller (DC) hai. Kerberos Authentication: Ye AD ka standard protocol hai. Ismein teen cheezein hoti hain: Client, Server, aur Key Distribution Center (KDC).

1. wo "Golden Ticket" bana kar poore network ka admin ban sakta hai. Client KDC ko request bhejta hai.
2. KDC ek Ticket Granting Ticket (TGT) deta hai.
3. Client us ticket ko use karke specific resource (jaise File Server) ke liye access token maangta hai. Hacking mein, agar attacker TGT chori kar le, to

2. Network Penetration Testing ki Methodology (Life Cycle) kya hai?

Answer: Ek professional penetration test 5 main stages se guzarta hai:

1. Reconnaissance (Information Gathering): Target network ki IP range, open ports, aur active services ka pata lagana (Tools: Nmap, Whois).
2. Enumeration: Network par maujood users, groups, aur machines ki list nikalna (Tools: CrackMapExec, Enum4linux).
3. Exploitation: Scanning mein mili kamzori (Vulnerability) ka faida utha kar system mein ghusna (Tools: Metasploit, Python scripts).
4. Post-Exploitation: System mein access milne ke baad data chori karna ya privilege badhana (Tools: Mimikatz, BloodHound).
5. Reporting & Persistence: Apne access ko permanent banana (Backdoor) aur poori activity ki report banana.

3. Privilege Escalation (Vertical vs Horizontal) ki wazahat karein.

Answer: * Vertical Privilege Escalation: Jab ek aam user (Standard User) apne aap ko Administrative level par le aaye. Misal ke taur par, Windows mein "Unquoted Service Path" ka faida utha kar system level ka access le lena.

- Horizontal Privilege Escalation: Jab ek user dusre user ke account ka access le le, jiska level uske barabar ho. Misal ke taur par, User A ka access use karke User B ki sensitive emails ya files par kabza karna.
- Hacker kaise karta hai: Hacker WinPEAS jaise tools run karta hai jo system ki misconfigurations (jaise weak passwords, misconfigured services) ko automatically scan karte hain.

4. Post-Exploitation aur Persistence ki techniques kya hain?

Answer: Ek baar system mein entry milne ke baad, hacker ye chahta hai ke system restart hone par bhi uska access khatam na ho:

- Registry Keys: **Run** aur **RunOnce** keys mein malware ka path dalna taake boot time par virus start ho jaye.
- Scheduled Tasks: Windows ke "Task Scheduler" mein ek aisa task banana jo har 1 ghante baad hacker ko connection wapas bheje.
- Golden Ticket Attack: Kerberos TGT ko forge (fake) karna, jis se hacker hamesha ke liye Domain Admin ka access rakh sakta hai, chahe asli password change bhi ho jaye.

5. Organization apne Active Directory ko Hack hone se kaise bachaye (Defensive Security)?

Answer: AD ko secure karne ke liye "Defense in Depth" strategy zaroori hai:

1. Least Privilege Principle: Har user ko sirf utni hi access dein jitni zaroorat hai. Domain Admin ka istemal har chote kaam ke liye na karein.
2. Multi-Factor Authentication (MFA): Password ke ilawa extra verification (App code/SMS) laazmi karein.
3. Patch Management: Windows server ko hamesha updated rakhein taake "EternalBlue" jaise exploits kaam na karein.
4. Auditing & Monitoring: Event Logs (ID 4624 - Success Login, 4625 - Failed Login) ko monitor karein. Agar koi mashkook activity ho, to foran alert generate ho.
5. Disable LLMNR/NBT-NS: Network mein hash poisoning se bachne ke liye in purane protocols ko disable karein.